IA6 Integration Testing and Security Hardening

Laurence Matthew B Manuel BSIT 3A PFEBSIT 002 Project 29 Week 15

Executive result

The Week 15 working tree is verified for the bounded Project 29 workflow in the controlled local environment. The live HTTPS collection passed 14 of 14 scenarios, Laravel passed 24 tests with 227 assertions, and Flutter passed 22 tests. Five real weaknesses from the Week 14 baseline were fixed, their original failures were rerun, and a client-layout regression found during the sprint was corrected. This is a tested prototype result, not a production-readiness claim.

System and test scope

The continuous Flutter Web and Laravel/MariaDB application supports consultation request, schedule confirmation, agenda, meeting status, action items, follow-up, reminders, missed-session handling, deadlines, progress summaries, and protected adviser exchange. Tests cover normal, invalid, boundary, unauthorized, forbidden, not-found, duplicate, timeout, dependency failure, rollback, and recovery. Loading, success, empty, validation, authentication, authorization, network, server error, desktop, tablet, and narrow client states are covered.

The build is an uncommitted Week 15 working tree based on commit `133b0c8`. Execution occurred on 2026-11-08 in Asia/Manila using PHP 8.2.12, Laravel 12.71.0, Flutter 3.47.8, Dart 3.13.7, and MariaDB 10.4.32. Exact times are machine-recorded in the environment and API result JSON.

Strategy decision

Layered automated tests plus a live HTTPS collection were selected over a collection-only approach. Collection-only testing is simpler and portable but cannot isolate database rollback, simulated transport states, malformed client responses, or widget layouts. The selected approach adds maintenance across Laravel, Flutter, and PowerShell/Postman artifacts, but gives a traceable requirement-to-evidence chain.

Results summary

Evidence set	Scope	Result
Live HTTPS collection	14 interoperability and adverse scenarios	14 passed
Laravel	workflow, auth, secure exchange, automation, rollback, hardening	24 tests, 227 assertions passed
Flutter	API interpretation, timeout, malformed output, visible states, widths	22 tests passed
Static/build	Pint, Flutter analysis, release web build	passed
Dependency/hygiene	Composer audit and generated-secret scan	no advisory; 244 files scanned, zero matches

The exported Postman collection contains ten portable requests. The PowerShell equivalent adds deterministic dependency failure/recovery and result capture without exporting credentials.

Defects and before-after evidence

Five targeted tests initially failed: pagination ignored `per_page`; an unauthorized panel reached cryptographic handling; CSP was absent; non-idempotent timeout advice encouraged retry; and malformed JSON was reported as a network outage. The final implementation provides validated pagination metadata, early receiver authorization, CSP/Permissions-Policy/HSTS, idempotency-aware timeout messages, and safe 502 protocol classification.

The first full Flutter regression then failed because visible validation counters increased the login form height. Removing the counters while retaining boundary validators restored all viewports. The older idempotent-timeout test was corrected to send the key required by its own expectation. `initial-failure-record.md`, `defect-records.md`, and `regression-results.md` preserve these facts.

Failure injection and recovery

An unavailable HTTPS endpoint was bounded to two seconds and followed by a successful call to the approved service. Simulated worker timeouts stopped after three attempts and required human review. A process crash after tentative receipt creation rolled back the receipt and attempt count; a later worker execution delivered exactly once. Duplicate request replay returned the existing resource, while changed content under the same key returned 409.

Client and server agreement

Both layers enforce agenda 5-1000 characters, action description 5-500, human resolution 10-500, future UTC timestamps, valid email up to 100, and password up to 128. The server remains authoritative. The client separately demonstrates loading, empty, authentication, authorization, network, server, and protocol failures with safe text and live-region status feedback.

Security hardening assessment

Authorization derives from the server-side session, not client role text. The secure receive route now rejects an ineligible actor before expensive cryptography and still authenticates recipient metadata during envelope opening. API responses use no-store, nosniff, no-referrer, CSP default-deny/frame denial, disabled camera/microphone/geolocation, and HSTS. Secrets remain in the backend private environment or ignored keyring. Correlation IDs support review without exposing tokens, keys, passwords, ciphertext, or real personal information.

Remaining risk executive summary

Risk	Current control	Residual concern	Priority
Duplicate action creation after ambiguous timeout	UI disables duplicate click; safe non-idempotent advice	no action-specific idempotency key	P2
Mutation abuse by an authenticated account	role checks; login/exchange throttles	other writes lack measured per-user rate policy	P2
Dataset growth	API pages 1-100 and visible has_more notice	UI has no page navigation	P2
Reverse proxy variance	local HTTPS headers verified	final proxy may replace headers	P2
Browser/accessibility variance	Edge evidence and widget semantics	independent browser/AT matrix not run	P3
Load/concurrency	transactions and isolated concurrency safeguards	capacity and thresholds not measured	Week 16

Reproduction and evidence map

Run `Invoke-Week15Api.ps1` for the live collection and `Run-Week15Verification.ps1` for the full automated gate. The traceability matrix links 25 requirements/risks to specific evidence. The editable Mermaid diagram shows client, HTTPS, API, data, dependency, failure, evidence, and backlog flows. `EVIDENCE_INDEX.md` identifies screenshots, logs, results, build state, and capture time.

Conclusion

The evidence supports IA6 completion for the controlled Week 15 scope. Every required adverse category has a repeatable test, five evidence-supported weaknesses were hardened, initial failures remain visible, and full regression passed. Broader deployment, performance, concurrency, and stakeholder acceptance remain explicitly pending for later authorized weeks.

Acknowledgment

AI assistance was used for code, tests, documentation, and evidence organization. The student reviewed the work against the original module, actual source, and executed results. Framework and testing guidance follows the official Postman, OWASP, Laravel, and Flutter sources appropriate to the installed versions.